

21/10/2025

Registre des violations de données personnelles : Cas du groupe B&B Hotels.

Test S4 ISI_C06



utt
UNIVERSITÉ DE TECHNOLOGIE
TROYES



Responsable pédagogique :

Marc LEMERCIER

Shakira IPOULE
RT3

Table des matières

Contexte	2
1) Tableau synthétique des violations de données personnelles (2023-2025)	3
2) Fiches détaillées d'incidents	4
Incident n°1 – Envoi d'un courriel à un destinataire erroné (février 2023)	5
Mesures prises :	6
Incident n°2 – Vol d'un ordinateur portable non chiffré (août 2023)	6
Mesures prises :	8
Incident n°3 – Hameçonnage ciblé sur des données du personnel (janvier 2024)	9
Mesures prises :	11
Incident n°4 – Intrusion externe dans la base marketing (septembre 2024)	12
Mesures prises :	14
Incident n°5 – Erreur d'envoi d'une facture client (mai 2025)	15
Mesures prises :	16
3) Annexes	17
Annexe 1 : Formulaire de notification CNIL (structure)	17
• Catégories de données personnelles concernées et volume approximatif	17
Annexe 2 : Modèle de communication aux personnes concernées	18
Annexe 3 : Correspondance avec le registre des traitements	19
Annexe 4 : Modèle de plan d'amélioration post-incident	20

Contexte

Le présent document constitue le **registre interne des violations de données personnelles** du groupe B&B Hôtels sur la période de janvier 2023 à octobre 2025. Il est élaboré conformément aux exigences du Règlement (UE) 2016/679, dit **RGPD**, et aux recommandations de la **CNIL** (Commission Nationale de l'Informatique et des Libertés) ainsi qu'aux lignes directrices du **CEPD** (Comité Européen de la Protection des Données). Son objectif est de **documenter de manière exhaustive** chaque incident de sécurité affectant des données personnelles au sein du groupe, afin d'assurer le suivi de la conformité et l'amélioration continue de la sécurité.

Conformément à l'**article 33(5) du RGPD**, le responsable du traitement doit documenter **toute violation de données à caractère personnel**, qu'elle fasse ou non l'objet d'une notification à la CNIL. Ce registre consigne donc chaque incident avec **les faits ayant conduit à la violation, les catégories de données et de personnes concernées, le nombre de personnes impactées, les conséquences constatées ou potentielles, et les mesures correctives prises**. Si, pour un incident donné, il a été décidé de **ne pas notifier** l'autorité de contrôle ou de **ne pas informer** les personnes concernées, le registre en apporte la **justification motivée**. Ce document interne n'est pas transmis systématiquement à l'autorité, mais doit être tenu à sa disposition en cas de contrôle, comme **preuve de conformité et de responsabilisation** (« *accountability* ») du groupe.

La notion de **violation de données personnelles** (ou *data breach*) désigne tout incident de sécurité – acte malveillant ou erreur – entraînant accidentellement ou illicitement la destruction, la perte, l'altération, la divulgation non autorisée de données personnelles ou l'accès non autorisé à de telles données. En d'autres termes, toute fuite de données identifiables, tout accès par une personne non autorisée ou toute perte définitive de données constitue potentiellement une violation devant être consignée. Ce registre couvre **l'ensemble des entités et activités du groupe B&B Hôtels** traitant des données personnelles, et inclut les violations de confidentialité, d'intégrité ou de disponibilité des données, qu'elles soient dues à des causes internes (erreur humaine, défaillance technique...) ou externes (cyberattaque, vol, etc.).

La **portée** de ce registre s'étend à tous les traitements de données personnelles gérés par le groupe, notamment les réservations clients, la facturation, la relation client (réclamations, fidélité), le marketing digital et la gestion des ressources humaines. Chaque incident est rattaché au traitement concerné (voir Annexe 3) pour faciliter le suivi et la mise en correspondance avec le **registre des activités de traitement** du groupe.

Il est important de noter que **toutes les violations ne donnent pas lieu à une notification** externe : cela dépend du **niveau de risque** que l'incident fait peser sur les droits et libertés des personnes concernées. Ainsi, **en l'absence de risque significatif**, l'incident est simplement documenté en interne et aucune notification n'est effectuée. Si l'incident présente un **risque pour les personnes**, le responsable du traitement notifie la CNIL dans les 72 heures suivant la prise de connaissance de la violation. En cas de **risque élevé** (par exemple, exposition de données sensibles ou susceptibles d'engendrer un préjudice important), **les personnes concernées sont également informées** dans les meilleurs délais, en plus de la notification à la CNIL. Cette approche graduée, explicitée par les articles 33 et 34 du RGPD, vise à concentrer l'information sur les cas les plus graves tout en garantissant une **documentation interne systématique de tous les incidents**, même mineurs.

Le registre est placé sous ma responsabilité du **DPO (Délégué à la Protection des Données)** du groupe, pour veiller à sa mise à jour après chaque incident et à son exploitation pour renforcer la sécurité. Des **revues régulières** de ce registre (par exemple, bilan annuel – voir Annexe 5) sont réalisées afin d'identifier les tendances, de mettre en œuvre des actions préventives et d'améliorer en continu les mesures de protection des données. Les termes techniques ou juridiques utilisés (tels que *violation de données*, *notification*, *personnes concernées*, *mesures correctives*, etc.) sont expliqués au fil du document afin d'en assurer la compréhension par des lecteurs non spécialistes du domaine juridique ou de la cybersécurité.

1) Tableau synthétique des violations de données personnelles (2023-2025)

Le tableau ci-dessous dresse la **liste chronologique des violations de données personnelles** recensées au sein du groupe entre janvier 2023 et octobre 2025. Pour chaque incident, sont indiqués la date, la nature de l'incident, les données et personnes affectées, le **niveau de risque estimé** ainsi que les actions de notification entreprises. Ce récapitulatif permet une vue d'ensemble rapide de la période considérée.

Date (découverte)	Nature de la violation	Données & personnes concernées	Niveau de risque	Notification CNIL	Information personnes
10/02/2023	Envoi erroné de données clients à un tiers non autorisé	Clients (noms, emails, détails de réservation) ~50 personnes	Modéré	Oui (72h)	Non (<i>risque modéré</i>)

	(erreur humaine)				
21/08/2023	Vol d'un ordinateur portable non chiffré contenant une base de données clients	Clients (noms, coordonnées, historiques de réservation) ~15 000 personnes	Élevé	Oui (72h)	Oui (notification individuelle)
15/01/2024	Phishing – Envoi frauduleux de données du personnel à un attaquant externe	Personnel (données RH : noms, adresses, NIR, salaires) 312 personnes	Élevé	Oui (72h)	Oui (information des employés)
30/09/2024	Intrusion externe dans la base marketing (exfiltration de la liste d'abonnés)	Clients/prospects (prénoms, emails) ~20 000 personnes	Modéré	Oui (72h)	Non (<i>données non sensibles</i>)
05/05/2025	Envoi d'une facture client à une mauvaise adresse e-mail	Client (nom, détails de réservation, montant facture) 1 personne	Faible / Aucun	Non (<i>documenté seulement</i>)	Non (<i>risque négligeable</i>)

(**Note** : « Modéré » indique un risque suffisant pour justifier une notification à la CNIL mais pas d'information systématique des personnes concernées. « Élevé » indique un risque élevé nécessitant également une information directe des personnes concernées conformément à l'article 34 RGPD. « Faible/Aucun » indique un risque jugé inexistant ou très limité ne nécessitant ni notification externe ni alerte individuelle.)

2) Fiches détaillées d'incidents

Pour chacun des incidents listés ci-dessus, une **fiche détaillée** est présentée ci-après. Chaque fiche suit un format structuré incluant : les **faits** (description de l'incident et circonstances de découverte), les **données personnelles concernées** (types de données et nombre de personnes affectées), l'évaluation du **risque** et des **conséquences** potentielles, les actions de **notification** effectuées (ou la justification de leur absence), les **mesures prises** pour remédier à l'incident et éviter sa répétition, ainsi que le **suivi** et l'état de résolution. Ces fiches fournissent une traçabilité complète de la gestion de chaque violation.

Incident n°1 – Envoi d'un courriel à un destinataire erroné (février 2023)

Faits : Le 10 février 2023, un collaborateur du service clientèle a envoyé par erreur un **courriel** contenant un fichier de données clients à un destinataire externe non autorisé (un client ayant formulé une demande sans lien avec ces données). L'erreur est survenue lors d'un échange par email relatif à une réclamation : le fichier joint, censé être une réponse personnalisée, contenait en réalité un extrait de la base de données clients. L'incident a été découvert quelques heures plus tard, lorsqu'un client destinataire a signalé avoir reçu des informations ne le concernant pas. Dès ce signalement, le DPO et la direction ont été alertés, et une analyse a été lancée pour identifier l'ampleur de la fuite.

Données personnelles concernées : Le fichier transmis par inadvertance comportait des données relatives à **environ 50 clients** du groupe. Ces données incluaient les **noms, prénoms, adresses email, numéros de téléphone** de ces clients, ainsi que des informations sur leurs **réservations récentes** (hôtels fréquentés, dates de séjour). Aucune donnée sensible (pas de données de paiement, pas de données d'identification officielle) n'était présente dans le document. Les personnes affectées sont exclusivement des **clients** ayant réservé un séjour au cours des derniers mois précédant l'incident.

Risque et conséquences potentielles : L'impact principal de cette violation est un **risque d'atteinte à la confidentialité** des informations clients. Le destinataire non autorisé a pu prendre connaissance de coordonnées et détails de séjours d'autres clients, ce qui constitue une violation de leur vie privée. Toutefois, ce risque est demeuré **limité** : les données exposées ne sont pas hautement sensibles et ont été vues par un seul destinataire identifiable. Le principal risque est que ce destinataire utilise ou divulgue ces informations (par exemple, en contactant les clients ou en les exposant publiquement). Néanmoins, étant lui-même client de l'entreprise, il n'avait a priori aucune intention malveillante déclarée lors de la découverte. Aucun préjudice matériel immédiat n'a été constaté pour les personnes (pas de fraude ni d'usurpation d'identité signalée). En résumé, le risque a été évalué comme **modéré** : l'incident pouvait potentiellement porter atteinte à la vie privée des individus concernés (par la diffusion non maîtrisée de leurs données de contact et informations de séjour), sans toutefois menacer gravement leurs droits ou libertés (pas de données financières ou sensibles impliquées).

Notification : Conformément aux obligations légales, une **notification à la CNIL** a été effectuée dans un délai de 72 heures suivant la détection de l'incident. Le DPO a soumis le formulaire de notification via le téléservice dédié dès le 12 février 2023, en fournissant les informations requises (nature de la violation, nombre de personnes concernées, catégories de données, mesures prises, etc.). Étant donné que le risque pour les personnes concernées était jugé limité et maîtrisé, il n'a **pas été jugé nécessaire d'informer individuellement** les clients dont les données ont été involontairement divulguées. En effet, l'incident a été contenu rapidement et ne concernait pas de données sensibles ; une information directe des 50 clients aurait pu les alarmer inutilement. Cette décision de ne pas procéder à une notification aux personnes concernées est **documentée et justifiée** dans le registre (risque faible, engagement du destinataire à supprimer les données). Le destinataire ayant reçu par erreur le fichier a été contacté immédiatement afin de **s'assurer de la suppression** des données reçues et de sa non-divulgateion.

Mesures prises :

- **Rappel des bonnes pratiques** : Un rappel formel des règles de messagerie a été adressé à tout le personnel (vérification systématique des pièces jointes et des destinataires avant envoi, utilisation modérée des fonctions "Répondre à tous" et des listes de diffusion).
- **Sensibilisation ciblée** : Une formation/sensibilisation spécifique a été organisée pour l'équipe du service clientèle concernée, afin de renforcer la vigilance lors de l'envoi de courriels contenant des données personnelles.
- **Avertissement automatique** : Un mécanisme d'alerte a été ajouté dans le logiciel de messagerie : toute tentative d'envoi externe d'un fichier comportant des données personnelles déclenche désormais une demande de confirmation à l'expéditeur.
- **Protection des documents** : Les documents contenant des données clients transmis en externe doivent dorénavant être protégés par mot de passe ou via un lien sécurisé. Ainsi, même en cas d'envoi à un mauvais destinataire, le contenu ne sera pas directement accessible sans la clé.

Suivi : L'incident a été **clos** opérationnellement le 15 février 2023, après vérification que le fichier en question avait bien été supprimé par le destinataire involontaire et que celui-ci s'était engagé formellement (par écrit) à ne pas en conserver copie. Aucune diffusion secondaire des données n'a été détectée dans les semaines suivant l'événement. Le DPO a archivé une copie de la notification effectuée à la CNIL et a consigné la description de l'incident ainsi que les mesures prises dans le présent registre. Un **retour d'expérience** a été réalisé en interne afin d'insister sur l'importance de la vigilance lors du traitement des données personnelles au quotidien. Enfin, lors du bilan annuel 2023, cet incident a été réexaminé pour s'assurer que les mesures correctives (notamment les nouvelles procédures d'envoi sécurisé et la formation du personnel) sont bien en place et respectées.

Incident n°2 – Vol d'un ordinateur portable non chiffré (août 2023)

Faits : Le 21 août 2023, un **ordinateur portable professionnel** appartenant à un chef de projet informatique du groupe a été **dérobé** dans un véhicule stationné. L'employé, en déplacement, avait stocké temporairement l'appareil dans sa voiture de fonction. À son retour, il a constaté l'effraction du véhicule et la disparition de l'ordinateur. L'appareil contenait localement une **copie de travail** d'une base de données clients utilisée pour des tests (une erreur de procédure, car des données réelles n'auraient pas dû se trouver sur un poste nomade non sécurisé). Le vol a été immédiatement signalé aux autorités locales (dépôt de plainte) et remonté en interne le jour même. Le 22 août 2023, l'équipe IT et le DPO ont analysé l'incident pour évaluer les données potentiellement compromises et les risques induits.

Données personnelles concernées : L'ordinateur volé contenait une **extraction substantielle de la base de données "réservations clients"** du groupe. Environ **15 000 clients** (principalement en France et en Europe) sont potentiellement affectés. Les données comprenaient les **informations d'identification et de contact** (nom, prénom, adresse postale, email, téléphone) des clients, ainsi que des **données relatives à leurs réservations** passées (hôtels fréquentés, dates de séjour, préférences de chambre éventuelles). Certains enregistrements comprenaient également des **informations de fidélité** (numéro de membre du programme de fidélité, points accumulés). En revanche, aucune donnée de carte bancaire complète n'était stockée sur ce poste (les transactions de paiement n'étant pas traitées en local) – seules les quatre derniers chiffres des cartes pouvaient apparaître dans certains historiques de réservation. Aucune donnée sensible de type "catégories particulières" (origine ethnique, santé, etc.) n'était présente ; toutefois figuraient éventuellement la **nationalité** et la **préférence linguistique** de certains clients (informations fournies lors de la réservation). L'ordinateur étant protégé par un mot de passe d'ouverture de session standard mais **non chiffré**, les données qu'il contenait sont considérées comme potentiellement accessibles au voleur.

Risque et conséquences potentielles : Cet incident représente un **risque élevé** pour les personnes concernées du fait de la **quantité importante de données** impliquées et de la **malveillance potentielle** attachée à l'acte (vol ciblé ou opportuniste). En effet, un tiers non autorisé dispose potentiellement d'informations personnelles sur des milliers de clients. Les conséquences possibles incluent : **usage frauduleux des données** (tentatives d'escroquerie par phishing en se faisant passer pour B&B Hôtels auprès des clients listés, campagnes de spam, etc.), **atteinte à la vie privée** (divulcation publique des listes de clients et de leurs habitudes de séjour), voire un risque d'**usurpation d'identité** partielle si, par recoupement, le voleur dispose d'autres informations sur ces personnes. Bien que les données financières complètes ne soient pas compromises, les coordonnées et détails de réservations pourraient être exploités de manière nuisible. De plus, l'incident risque d'engendrer une **perte de confiance** de la clientèle envers le groupe en cas de diffusion publique. L'analyse a toutefois révélé que les données en question datent majoritairement de l'année 2022 et antérieures, ce qui signifie que certaines informations (emails, adresses) pourraient ne plus être à jour pour tous les clients. En résumé, le scénario du pire envisagé serait une **publication de la base volée sur Internet** ou son utilisation par un groupe criminel pour cibler les clients ;

compte tenu de ces facteurs, le niveau de risque est considéré comme **élevé** (risque avéré pour les droits et libertés, notamment le droit à la vie privée et la protection des données).

Notification : Compte tenu du risque élevé identifié, l'incident a été **notifié à la CNIL** dans les délais réglementaires : une notification initiale a été soumise le 23 août 2023 via le formulaire en ligne, soit environ 48h après la constatation du vol (dès que l'inventaire précis des données contenues sur l'appareil a pu être établi). Toutes les informations requises ont été communiquées, y compris les circonstances du vol, la nature et le volume des données concernées et les premières mesures de remédiation prises. En outre, étant donné le risque élevé pour les personnes, il a été décidé d'**informer individuellement l'ensemble des clients concernés** par la violation. Une **communication aux personnes** a été préparée en coordination avec le service relation client et validée par le DPO : un **courriel d'information** a été adressé, à partir du 25 août 2023, à chacun des clients dont les données figuraient dans la base volée (lorsque leur adresse email était disponible). Dans ce message, le groupe a expliqué la nature de l'incident, les informations potentiellement compromises, les **conséquences possibles** (par exemple, augmentation du risque de tentatives de phishing se faisant passer pour B&B Hôtels) et a prodigué des **recommandations** de vigilance (comme le fait de se méfier des communications suspectes, et de contacter l'hôtel en cas de doute sur l'authenticité d'un message). Les clients ont également été invités à mettre à jour leurs coordonnées sur leur compte en ligne par précaution. Pour les clients dont seules les coordonnées postales étaient disponibles ou dont l'email n'était plus valide, un **courrier postal** d'information a été envoyé dans la semaine suivant l'incident. Une **FAQ en ligne** a été mise en place sur le site web du groupe pour répondre aux questions des clients inquiets. L'ensemble de ces actions d'information a été finalisé début septembre 2023.

Mesures prises :

- **Containement immédiat :** Juste après le vol, l'équipe IT a tenté sans succès d'activer à distance l'effacement des données sur l'ordinateur dérobé. Par précaution, tous les accès potentiellement compromis (comptes VPN, messagerie, etc.) ont été révoqués ou modifiés dans les heures suivantes. Une analyse des journaux (*logs*) du réseau a été menée afin de détecter toute connexion suspecte en provenance de l'appareil volé (aucune anomalie constatée).
- **Chiffrement systématique :** Une solution de chiffrement complet du disque a été déployée en urgence sur 100% des ordinateurs portables du groupe, avec authentification requise au démarrage. Ainsi, la perte ou le vol d'un appareil ne pourra plus exposer les données qu'il contient.
- **Règles de stockage :** Un rappel strict de l'interdiction de stocker des données personnelles en local sur un poste nomade a été diffusé. Des contrôles aléatoires seront effectués pour s'assurer du respect de cette règle (en privilégiant l'utilisation de données fictives pour les tests et travaux hors-ligne).

- **Sécurité physique** : Les consignes de sécurité physique ont été renforcées : ne plus laisser d'ordinateur contenant des données sans surveillance, même dans un véhicule verrouillé. Des dispositifs antivol (câbles de sécurité) ont été fournis aux collaborateurs en déplacement afin de sécuriser les ordinateurs dans les lieux publics ou chambres d'hôtel.
- **Formation** : Un programme de formation spécifique a été lancé dès septembre 2023 à destination des équipes informatiques et chefs de projet, portant sur la protection des données en mobilité et le respect des protocoles de sécurité. Ce programme insiste notamment sur les bonnes pratiques (chiffrement, sauvegarde, utilisation de données simulées) et sur les retours d'expérience de cet incident.

Suivi : Cet incident a fait l'objet d'un **suivi renforcé sur la durée**. Dans les mois qui ont suivi, aucune divulgation publique des données volées n'a été constatée (une veille internet et *dark web* a été mise en place avec l'aide d'un prestataire spécialisé pour surveiller d'éventuelles apparitions de la base de données dérobée). Un seul cas de tentative de phishing potentiellement lié a été rapporté par un client (réception d'un email suspect prétendant provenir de B&B Hôtels en octobre 2023) ; il n'est pas établi avec certitude qu'il soit en lien avec la fuite, mais par précaution l'information a été remontée aux autorités compétentes. L'entreprise a fourni son **assistance aux clients** ayant des questions ou souhaitant exercer leurs droits (aucune demande d'effacement spécifique liée à l'incident n'a été reçue). L'incident a été formellement clos en décembre 2023 après la mise en œuvre de l'ensemble des actions correctives prévues (chiffrement déployé sur 100% des ordinateurs portables, formation dispensée à tous les employés concernés). Le registre interne a été mis à jour avec le détail des actions menées. Le DPO conserve la copie de la notification faite à la CNIL et la correspondance avec celle-ci (accusé de réception reçu le 24 août 2023). Enfin, lors de la revue annuelle, cet incident a été examiné en Comité de direction pour **tirer les leçons** en matière de sécurité : il a été un déclencheur pour investir dans des outils supplémentaires de protection (comme un système de suivi et effacement à distance pour les terminaux, actuellement en cours d'étude).

Incident n°3 – Hameçonnage ciblé sur des données du personnel (janvier 2024)

Faits : Le 15 janvier 2024, le service des ressources humaines du siège a été victime d'une **attaque de type "phishing" ciblé (hameçonnage)**. Un courriel usurpant l'identité d'un dirigeant du groupe (email falsifié se rapprochant de l'adresse du directeur financier) a été envoyé à une cadre du service RH. Dans ce message frauduleux, présenté comme "urgent et confidentiel", le pseudo-dirigeant sollicitait la transmission d'un **fichier contenant des données du personnel** dans le cadre d'un prétendu audit interne. Pensant répondre à une demande légitime de sa hiérarchie, la collaboratrice a extrait un fichier de la base RH et l'a envoyé par email à l'expéditeur, sans réaliser qu'il s'agissait d'une adresse externe malveillante. Quelques heures plus tard, ayant des doutes (en raison de l'insistance inhabituelle du correspondant), elle a contacté directement le directeur financier, qui a démenti toute demande de ce type. **L'incident a été immédiatement identifié** comme une fraude. Le DPO et le RSSI (Responsable de la Sécurité des Systèmes d'Information) ont été

alertés le jour même. Des actions techniques (notamment la collecte des en-têtes du mail frauduleux) et organisationnelles (information de la direction générale, dépôt d'une plainte pénale) ont été enclenchées dans la foulée.

Données personnelles concernées : Le fichier transmis illicitement contenait des **données à caractère personnel sur l'ensemble des employés** du groupe en France, ainsi que sur certains employés dans d'autres pays (fichiers combinés). Au total, environ **312 personnes (employés et ex-employés récents)** sont concernées. Les données envoyées incluaient : *identité* (nom, prénom, date de naissance), *coordonnées personnelles* (adresse postale, email, téléphone), *informations administratives* (numéro de Sécurité sociale – NIR, nationalité), *informations d'emploi* (poste, service, lieu de travail), ainsi que des données de paie (*salaires brut mensuel, primes, IBAN bancaire* pour le virement des salaires). Par chance, le fichier ne comportait pas de données sensibles au sens de l'article 9 RGPD (pas de données de santé, pas d'informations sur les origines raciales ou opinions des employés, etc.), mais il contenait néanmoins des données **hautement personnelles et confidentielles** (rémunérations, identifiants administratifs, coordonnées bancaires). Cette fuite concerne des **personnes internes** à l'entreprise (le personnel), dont certaines occupent des postes sensibles (cadres dirigeants dont les salaires ont été exposés).

Risque et conséquences potentielles : Cette violation de données est considérée comme **grave**, avec un niveau de risque **élevé** pour les employés concernés. En effet, la nature des données divulguées (NIR, coordonnées bancaires, salaire) expose les individus à des **risques concrets d'usurpation d'identité et de fraude**. Par exemple, le numéro de Sécurité sociale combiné à l'identité pourrait être utilisé pour usurper l'identité d'un employé auprès d'organismes (banques, assurance maladie, etc.), et les informations bancaires pourraient servir à des tentatives d'escroquerie financière. La connaissance des salaires et avantages peut également porter atteinte à la **vie privée** et causer un **préjudice moral** (divulgaration non autorisée d'informations considérées comme sensibles ou sources de discriminations). De plus, l'attaquant étant d'origine externe et ayant délibérément piégé l'entreprise, on peut craindre un usage malveillant effectif des données : revente sur des forums clandestins, tentative de chantage, ou ciblage des employés pour d'autres attaques (phishing personnalisé, par exemple en se faisant passer pour la banque de l'employé). Les conséquences pour l'entreprise ne sont pas négligeables non plus : outre l'atteinte à la confiance du personnel, il existe un risque de non-conformité réglementaire important si la situation n'est pas gérée correctement, et éventuellement un risque juridique (les personnes concernées pourraient engager des actions si elles subissent un préjudice). En résumé, les **droits et libertés** des employés touchés (protection des données personnelles, secret de la vie privée, sécurité financière) sont potentiellement menacés de manière significative, ce qui justifie le classement en **risque élevé**.

Notification : Le DPO a procédé à une **notification immédiate** de la violation auprès de la CNIL, compte tenu du risque élevé. La notification a été soumise le 16 janvier 2024 (moins de 24h après la découverte), avec l'ensemble des informations disponibles à ce stade. Par ailleurs, conformément à l'article 34 du RGPD, le groupe a **informé sans délai les personnes**

concernées, à savoir l'ensemble des employés dont les données figuraient dans le fichier. Le 17 janvier 2024, une **réunion exceptionnelle** du personnel a été organisée par la Direction des Ressources Humaines pour expliquer l'incident aux équipes (tout en préservant l'enquête en cours). Dans la foulée, un **courriel nominal** a été envoyé à chaque employé touché détaillant la nature des données compromises et les **mesures de précaution** à prendre. Ces mesures comprenaient notamment : la surveillance des comptes bancaires pour détecter toute opération suspecte, la vigilance accrue vis-à-vis de tout courriel ou appel téléphonique suspect prétendant provenir d'une entité officielle (banque, administration, etc.), et la recommandation de signaler rapidement toute tentative d'usage abusif de leurs informations. Il a également été suggéré aux employés de mettre en place des **alertes de sécurité** auprès de leur banque (par exemple, double vérification pour les transactions inhabituelles) et de contacter les organismes compétents (banque, assurance maladie) pour signaler que leurs données ont pu être compromises. Dans ce mail d'information, les coordonnées du DPO ont été fournies comme point de contact pour toute question ou exercice de droits. Une **hotline interne** a été mise en place temporairement pour assister les employés inquiets ou affectés.

Mesures prises :

- **Enquête et analyse** : Une enquête interne DSI/DPO a été menée pour disséquer le mode opératoire de l'attaque. Il a été confirmé qu'il s'agissait d'une manipulation par ingénierie sociale sans intrusion technique directe dans les systèmes (aucune brèche informatique parallèle n'a été détectée).
- **Sécurité de la messagerie** : Les filtres de sécurité de la messagerie ont été renforcés. Notamment, la détection des emails usurpant des adresses proches de celles du groupe a été améliorée et une bannière d'avertissement "[EXTERNE]" est désormais apposée sur tous les emails provenant de l'extérieur, pour alerter visuellement les destinataires internes.
- **Procédures internes** : Les procédures ont été mises à jour pour intégrer une vérification systématique en cas de demande de transmission de données sensibles par email. Toute demande inhabituelle doit faire l'objet d'une confirmation par un canal alternatif (par exemple, appel téléphonique direct au demandeur officiel) avant d'être exécutée.
- **Sensibilisation du personnel** : Un rappel strict des obligations de confidentialité et de vigilance a été communiqué aux managers et aux équipes manipulant des données sensibles. L'accent a été mis sur la responsabilité de chacun dans la protection des données, même face à des communications apparemment légitimes mais non conformes aux procédures.
- **Formation anti-phishing** : Un module de formation dédié a été déployé en février 2024 pour l'ensemble des salariés du groupe, comportant des exemples concrets de tentatives d'hameçonnage et les réflexes à adopter pour s'en prémunir. Des

campagnes de simulation d'attaques ont également été programmées pour tester et renforcer ces acquis.

- **Coordination avec les autorités :** L'entreprise a signalé l'attaque aux autorités compétentes (police/cybercriminalité) en leur transmettant les éléments du courriel frauduleux (adresse expéditrice, contenu, etc.). Bien que les auteurs n'aient pas été identifiés, cette coopération contribue à la lutte plus large contre ce type de fraude.

Suivi : Durant les mois qui ont suivi, le DPO a maintenu un contact régulier avec les employés concernés pour **mesurer l'impact** de l'incident. Heureusement, jusqu'à octobre 2025, aucun cas avéré d'usurpation d'identité ou de dommage financier directement relié à cette fuite n'a été signalé par les employés. Néanmoins, plusieurs employés ont proactivement fait modifier leur numéro de Sécurité sociale (lorsque c'était possible dans le cadre d'une procédure administrative de précaution) et renouvelé leurs identifiants bancaires, en partie grâce à l'accompagnement de l'entreprise (qui s'est engagée à couvrir les éventuels frais liés à ces changements pour les employés concernés). Le plan de formation anti-phishing lancé suite à l'incident a montré des résultats positifs lors de campagnes de test interne (*phishing simulation*) ultérieures, avec un taux de détection des faux emails en nette amélioration. L'incident est considéré comme **clôt** du point de vue de la gestion de crise, mais un **suivi à long terme** est en place : le DPO conserve une veille sur d'éventuelles fuites des données sur internet et reste disponible pour toute nouvelle requête ou assistance aux employés. Cet événement a été discuté lors du Comité Social et Économique (CSE) suivant, afin d'assurer la transparence vis-à-vis des représentants du personnel et de prendre en compte leurs suggestions en matière de protection des données des employés. La documentation du registre a été mise à jour avec minutie, incluant la justification de toutes les décisions (notifications, mesures correctives) pour assurer la traçabilité complète de la démarche de conformité.

Incident n°4 – Intrusion externe dans la base marketing (septembre 2024)

Faits : Le 30 septembre 2024, une **intrusion informatique** a été détectée sur l'un des serveurs web du groupe B&B Hôtels, hébergeant la **base de données marketing** (notamment la liste des abonnés aux newsletters et offres promotionnelles). L'équipe technique a observé des requêtes suspectes dans les journaux (*logs*) du serveur et un ralentissement inexplicable de l'application web. Après analyse, il est apparu qu'un tiers non autorisé avait exploité une **vulnérabilité** dans un module du site internet (vulnérabilité de type injection SQL) lui permettant d'extraire des données de la base clients/prospects. L'intrusion a été confirmée et colmatée le même jour : le vecteur d'attaque a été identifié (une faille dans un plugin de gestion de formulaire d'abonnement) et la brèche a été refermée immédiatement par une mise à jour logicielle d'urgence. Les premières investigations indiquent que l'attaque a pu débuter environ une semaine plus tôt (aux alentours du 22 septembre 2024), période durant laquelle l'attaquant a pu exfiltrer progressivement des données. L'activité malveillante a été stoppée dès la découverte le 30 septembre. L'attaque semble avoir été automatisée et non spécifiquement ciblée sur B&B Hôtels (le plugin

vulnérable étant largement répandu, l'attaquant balayait sans doute plusieurs sites vulnérables). Aucune demande de rançon ou revendication n'a été reçue.

Données personnelles concernées : La base de données affectée contenait principalement des informations de contact liées aux activités de **marketing et prospection** du groupe. Environ **20 000 enregistrements** ont été identifiés comme ayant pu être copiés par l'attaquant. Ces enregistrements concernent des **clients** et **prospects** inscrits aux newsletters ou programmes promotionnels. Les données en question comprennent essentiellement : *nom, prénom, adresse email*, et le cas échéant la *langue préférée* pour la communication. Dans certains cas (formulaire de profil client), on peut trouver aussi la *ville de résidence* ou le *pays*. Aucune donnée financière n'est stockée dans cette base marketing, ni aucune donnée sensible particulière – il s'agit de données d'annuaire utilisées à des fins de communication commerciale. Il est à noter que parmi les adresses emails concernées, certaines appartiennent peut-être à d'anciens clients ou prospects inactifs. Néanmoins, l'ensemble de ces adresses sont désormais potentiellement en possession de l'attaquant. Le nombre précis de personnes uniques touchées est difficile à établir (certaines adresses peuvent être des doublons ou alias), mais on l'estime autour de 18 000 individus distincts.

Risque et conséquences potentielles : Sur le plan de la **confidentialité**, cette violation reste limitée à des données de contact de base, ce qui circonscrit le risque. Il n'y a pas d'élément hautement sensible exposé (pas de mots de passe, pas de données personnelles délicates). Le **risque principal** réside en la possible utilisation malveillante des adresses emails et noms collectés : par exemple, les personnes concernées pourraient être ciblées par des **campagnes de spam** accrues ou des **tentatives de phishing** se faisant passer pour l'entreprise (puisque l'attaquant sait qu'elles ont un lien avec B&B Hôtels et pourraient ouvrir un email relatif à cette marque). Cela pourrait mener certains clients moins vigilants à divulguer des informations supplémentaires ou à subir des nuisances (réception d'emails indésirables). On peut aussi évoquer un risque de **perte de confiance** des clients dans les communications marketing du groupe, s'ils viennent à apprendre l'incident (doute sur l'authenticité des emails reçus). Cependant, le **risque pour les droits et libertés** des personnes demeure globalement **modéré** : la divulgation d'une adresse email, d'un nom et éventuellement d'une ville de résidence est un **préjudice limité** qui n'entraîne pas, en soi, de conséquences directes graves pour la personne (comparativement à une fuite de données financières ou d'identité). A priori, la plus grosse conséquence pourrait être une gêne (spam supplémentaire, nécessité de rester vigilant face à des arnaques potentielles). L'entreprise a évalué qu'avec les mesures de remédiation et de communication adéquates, ce risque restait sous contrôle et ne justifiait pas la qualification de "risque élevé" au sens du RGPD.

Notification : Dès confirmation de l'intrusion, une **notification à la CNIL** a été effectuée (le 1er octobre 2024) pour signaler la violation, conformément à l'article 33 du RGPD. Le formulaire soumis mentionnait la nature de l'attaque, le type de données concernées (emails, identités), le nombre approximatif d'enregistrements impliqués, ainsi que les mesures prises pour y mettre fin et en atténuer les effets. En ce qui concerne les personnes concernées, étant donné le caractère modéré du risque et l'absence de données critiques, le groupe a estimé

non nécessaire d'informer individuellement chaque contact de cette fuite. En effet, une notification individuelle à près de 18 000 personnes pour leur signifier que leur adresse email a pu être obtenue par un tiers aurait pu être perçue comme anxiogène, voire être confondue elle-même avec du spam par les destinataires. Néanmoins, dans une optique de transparence, le groupe a choisi de publier une **information générale** sur son site web corporate, dans la section "Actualités", le 5 octobre 2024. Cette publication, rédigée en des termes accessibles, expliquait qu'un incident de sécurité avait pu toucher la base d'adresses email, que des mesures avaient été prises et rappelait aux clients de faire preuve de vigilance vis-à-vis d'emails suspects. Un point de contact (l'adresse du DPO) y était également indiqué pour toute personne souhaitant des renseignements supplémentaires. La CNIL n'a pas demandé d'actions supplémentaires suite à la notification, le cas ayant été considéré comme géré de manière appropriée.

Mesures prises :

- **Correctif et audit :** La faille de sécurité identifiée sur le site web a été immédiatement corrigée (patch appliqué au module vulnérable). Un audit du code de l'application web a été lancé pour repérer d'autres vulnérabilités similaires et y remédier.
- **Renforcement des accès :** Tous les mots de passe des comptes administrateur du site et du serveur ont été réinitialisés avec des niveaux de complexité élevés. L'accès à l'interface d'administration a été temporairement restreint aux adresses internes de l'entreprise, le temps de mettre en place des protections supplémentaires.
- **Analyse forensique :** Une société de sécurité externe a conduit une analyse forensique approfondie de l'incident. Celle-ci a confirmé l'ampleur exacte de l'exfiltration (environ 20 000 enregistrements) et a vérifié qu'aucune autre donnée ou système interne n'avait été compromis durant l'attaque.
- **Surveillance accrue :** Un pare-feu applicatif web (**WAF**) a été déployé en frontal du site internet pour filtrer les requêtes malveillantes. Par ailleurs, la surveillance du trafic et des accès a été renforcée (mises en place d'alertes en temps réel en cas de comportement anormal ou de tentative d'intrusion).
- **Test de pénétration :** Un test d'intrusion complet du site web a été commandité (et réalisé en novembre 2024) afin d'éprouver les mesures de sécurité ajoutées. Les recommandations issues de ce test ont été appliquées (améliorations de configuration, corrections de quelques points mineurs).
- **Gestion des données :** La politique de gestion des données marketing a été ajustée : une purge régulière des contacts inactifs de la base est désormais programmée, et une anonymisation des anciens profils non utilisés est envisagée pour limiter l'exposition de données personnelles.
- **Retour d'expérience :** Une session de retour d'expérience conjointe entre les équipes Marketing et IT a été organisée pour analyser la gestion de l'incident et

améliorer le plan de réponse aux futurs incidents. Ce partage a permis d'affiner les rôles de chacun en cas d'alerte et de mettre à jour les procédures d'escalade.

Suivi : Aucune exploitation malveillante évidente des données volées n'a été portée à la connaissance de l'entreprise dans les mois qui ont suivi. Il est possible que les adresses collectées aient été revendues à des fins de spam générique. Quelques clients ont signalé, courant octobre-novembre 2024, une hausse de mails indésirables, sans que l'on puisse certifier un lien direct avec l'incident. Le DPO a conservé la communication sur le site pendant un mois et reste disponible pour toute personne ayant des interrogations. L'incident a été classé comme **résolu** opérationnellement fin octobre 2024, après la réalisation de l'audit de sécurité externe dont les recommandations ont été mises en œuvre. Le bilan de cet incident a été intégré à la formation continue des développeurs web du groupe, pour souligner l'importance du développement sécurisé (une session de sensibilisation aux OWASP Top 10 a été effectuée en décembre 2024). L'architecture de sécurité renforcée (WAF, surveillances) reste en place de façon permanente. Lors du bilan annuel 2024, il a été noté que cet incident – bien que d'impact limité – a servi de piqûre de rappel pour maintenir un haut niveau de sécurité sur les systèmes exposés à Internet.

Incident n°5 – Erreur d'envoi d'une facture client (mai 2025)

Faits : Le 5 mai 2025, une erreur humaine isolée est survenue au sein du service comptabilité (département **Facturation & Paiement**). Un assistant comptable a envoyé par courrier électronique une **facture client** à la mauvaise personne. Concrètement, en voulant transmettre la facture du séjour de M. X (client) à ce dernier, l'employé s'est trompé d'adresse électronique et l'a envoyée par inadvertance à un autre client du groupe ayant un nom similaire. L'erreur a été repérée rapidement : le destinataire erroné a répondu le jour même en signalant qu'il ne comprenait pas la raison de cet envoi, ce qui a permis d'alerter aussitôt le service concerné. L'incident a été circonscrit dans la journée suivant l'envoi.

Données personnelles concernées : La **facture PDF** envoyée par erreur contenait les données personnelles de **M. X**, à savoir : ses nom et prénom, son adresse postale, les dates et le détail de son séjour à l'hôtel (noms de l'hôtel, nuits passées, tarif), ainsi que le montant total facturé et un numéro partiel de carte bancaire (les 4 derniers chiffres, figurant sur la facture comme référence du moyen de paiement). Le destinataire ayant reçu par erreur ce document était un autre client du groupe, M. Y, dont seules l'adresse email et le nom figurent dans l'échange (M. Y n'est pas directement affecté en termes de divulgation de ses propres données, il a simplement reçu celles de M. X). En résumé, **une personne** (M. X) a vu ses données de facturation accidentellement divulguées à **une autre personne** (M. Y). Aucune donnée particulièrement sensible n'est présente (il s'agit essentiellement d'informations de réservation et de paiement partiel), mais ces informations sont tout de même confidentielles entre l'hôtel et M. X.

Risque et conséquences potentielles : L'incident est à portée **très limitée** : un seul client a été involontairement mis au courant de la réservation et du montant payé par un autre client. Les conséquences potentielles sur M. X sont faibles : M. Y, destinataire accidentel, n'a a priori

aucun intérêt particulier à exploiter ces informations (il s'agit d'un inconnu par rapport à M. X). On peut envisager une légère **atteinte à la vie privée** de M. X (puisque un tiers a pris connaissance de son séjour et du coût de celui-ci), et éventuellement une **gêne** si M. Y venait à connaître personnellement M. X (ce qui est hautement improbable étant donné la nature aléatoire de l'erreur). Le numéro partiel de carte bancaire n'a aucune utilité frauduleuse en soi (4 derniers chiffres uniquement). Le risque financier est donc **nul**. Le risque pour les droits et libertés de M. X a été évalué comme **négligeable**, voire inexistant en pratique, compte tenu de la bonne foi du destinataire M. Y qui a spontanément signalé l'erreur. En effet, le fait que M. Y ait immédiatement prévenu l'entreprise indique qu'il est digne de confiance et qu'il ne cherchait pas à exploiter ces données. En résumé, nous sommes face à un incident de **faible gravité**, sans dommage identifié pour la personne concernée, en dehors d'une possible contrariété liée à la confidentialité de ses achats.

Notification : Étant donné l'absence de risque significatif, aucune notification à la CNIL n'a été requise pour cet incident. L'événement a été entièrement **documenté en interne** au registre (présentement). Concernant la personne concernée (M. X), le groupe a choisi de ne **pas la contacter spécifiquement** au sujet de cette erreur, pour plusieurs raisons : (1) les données divulguées étaient d'une nature limitée et non sensibles, (2) l'erreur a été immédiatement corrigée (voir mesures prises) et le destinataire s'est engagé à détruire la facture, (3) informer M. X de l'incident risquerait de l'inquiéter outre mesure alors qu'aucune suite dommageable n'est à craindre. Cela est cohérent avec la réglementation, qui n'exige d'informer les personnes que si le risque pour elles est élevé – ce qui n'est pas le cas ici. En revanche, le **destinataire non autorisé** (M. Y) a été recontacté dès le 5 mai 2025 : le service comptabilité lui a présenté des excuses pour l'envoi erroné et lui a demandé expressément de **supprimer le document** reçu et de ne pas en faire usage. M. Y a confirmé par retour d'email avoir bien supprimé la facture et n'en avoir divulgué le contenu à personne. Cette correspondance est archivée en preuve.

Mesures prises :

- **Rappel immédiat :** Dès le lendemain, le responsable du service facturation a réuni son équipe pour rappeler l'importance de vérifier scrupuleusement les adresses e-mail des destinataires avant tout envoi de document sensible (facture ou autre). L'employé ayant commis l'erreur a reconnu l'inattention et a été recadré de manière pédagogique.
- **Double contrôle :** Une procédure interne a été ajoutée : pour tout envoi de facture par email, un collègue doit désormais relire l'adresse du destinataire (ou le courriel est envoyé en copie à un supérieur) afin de détecter immédiatement une éventuelle erreur d'adressage.
- **Portail client sécurisé :** Le groupe a accéléré le projet de mise en place d'un portail client en ligne permettant aux clients de récupérer eux-mêmes leurs factures de manière sécurisée. Ce système, en cours de développement, réduira à terme la nécessité d'envois manuels de factures par email.

- **Anonymisation des factures** : En attendant, le format des factures a été ajusté pour limiter les données personnelles affichées. Par exemple, les numéros de carte bancaire – même partiels – ne figureront plus sur les documents envoyés, afin d’éliminer tout risque lié à leur divulgation accidentelle.

Suivi : Cet incident a été résolu sur-le-champ et n’a pas eu de suite. Le client M. Y (destinataire erroné) a été remercié pour sa compréhension, et le client M. X a reçu sa facture sur la bonne adresse peu après, sans être informé de la confusion initiale. Aucun signe d’utilisation abusive des informations n’a été constaté par la suite. Le registre interne a été mis à jour pour garder la trace de l’événement, de son analyse et des mesures prises. Lors de la **revue annuelle de 2025**, cet incident sera intégré dans les statistiques et a déjà servi d’exemple lors d’une session de sensibilisation générale sur la confidentialité (tous les employés ont été invités à redoubler d’attention dans l’envoi d’emails contenant des données personnelles, même d’apparence anodine). L’incident est clos, et il est classé dans la catégorie des “**presque incidents**” (near miss) en ce qu’il n’a pas eu de conséquence préjudiciable, tout en offrant une leçon utile en termes de vigilance.

3) Annexes

Annexe 1 : Formulaire de notification CNIL (structure)

(Structure type basée sur le formulaire de notification de violation de la CNIL)

En cas de violation devant être notifiée, le responsable de traitement complète le formulaire en ligne de la CNIL en renseignant au minimum les informations suivantes :

- **Identité du responsable de traitement et du contact** : nom de l’organisme, adresse, et coordonnées du référent (DPO ou personne à contacter).
- **Date de la violation** ou période durant laquelle elle a eu lieu, et **date de découverte** de l’incident.
- **Nature de la violation** : description succincte de l’incident (ex. accès illégal, perte de matériel, envoi erroné, etc.), en précisant s’il s’agit d’une atteinte à la confidentialité, intégrité et/ou disponibilité des données.
- **Catégories de personnes concernées** et **nombre approximatif** : qui sont les personnes touchées (clients, employés, etc.) et en quelle quantité (même estimée).
- **Catégories de données personnelles concernées** et **volume approximatif** d’enregistrements : type de données (identité, coordonnées, données financières, etc.) et évaluation du nombre de lignes/entrées ou fichiers affectés.

- **Conséquences probables de la violation** : explication des effets potentiels de l'incident pour les personnes (risques identifiés, ex. vol d'identité, atteinte à la vie privée, pertes financières potentielles, etc.).
- **Mesures déjà prises pour remédier à la violation** et, le cas échéant, pour en limiter les conséquences négatives : mesures de confinement (isolement du système, récupération de données, etc.) et corrections apportées (ex. fermeture de la faille, rappel du mail, changement de mot de passe, etc.), ainsi que toute mesure de protection des personnes (ex. recommandation de changer un mot de passe).
- **Mesures envisagées pour l'avenir** : éventuellement, plan d'actions pour éviter qu'un incident similaire ne se reproduise (ex. améliorations de sécurité à venir, nouvelles procédures ou formations prévues).
- **Information des personnes concernées** : indication si, oui ou non, les personnes ont été ou seront notifiées de l'incident, et si non, justification (même si le RGPD n'exige pas ce point pour la notification à l'autorité, la CNIL peut interroger sur ce sujet).
- **Autres autorités de contrôle** concernées : si la violation touche des personnes dans d'autres pays de l'UE, préciser si d'autres autorités de protection des données ont été informées.
- **Pièce jointe** : possibilité de joindre un rapport plus détaillé si nécessaire ou d'autres documents utiles (par exemple, copie du message d'information envoyé aux personnes concernées).

Ces éléments forment la trame du formulaire de notification. Le DPO Claire Monfort s'assure que chaque champ est correctement rempli lors de la déclaration d'un incident, en s'appuyant sur les informations collectées auprès des équipes techniques et métiers impliquées. Une copie du formulaire soumis (ou le numéro de dossier attribué par la CNIL) est conservée avec la fiche de l'incident dans ce registre, afin d'assurer la traçabilité de la démarche de notification.

Annexe 2 : Modèle de communication aux personnes concernées

(Exemple de lettre/email type à adresser aux personnes concernées en cas de violation présentant un risque élevé.)

Objet : Information concernant la sécurité de vos données personnelles

Madame, Monsieur,

Nous tenons à vous informer qu'un **incident de sécurité** relatif à certaines de vos **données personnelles** est survenu le [date de l'incident]. Cet incident consiste en [**nature de la violation** : par ex., "un accès non autorisé à notre base de données clients"/"la perte d'un support contenant des données vous concernant"].

Quelles données sont concernées ? D'après nos analyses, les données potentiellement affectées comprennent : [liste des **catégories de données** vous concernant, par ex. "vos coordonnées (adresse email, numéro de téléphone) et des informations sur vos dernières réservations"]. Nous souhaitons vous rassurer que [si applicable : ex. "vos données de paiement (numéro de carte bancaire) ne sont pas concernées par cet incident"].

Quelles sont les conséquences potentielles ? À ce jour, nous n'avons pas d'élément indiquant un usage malveillant de vos données. Cependant, il existe un **risque** que ces informations soient utilisées à des fins non autorisées. Concrètement, vous pourriez être exposé(e) à [**conséquences probables** : ex. "des tentatives d'hameçonnage (**phishing**) – c'est-à-dire la réception d'emails ou d'appels se faisant passer pour notre société pour obtenir d'autres informations de votre part"]. Nous vous invitons donc à la plus grande **vigilance** dans les prochaines semaines. En particulier, soyez attentif(ve) à tout message suspect prétendant provenir de B&B Hôtels ou d'un tiers demandant des informations confidentielles.

Quelles mesures sont prises ? Nous avons immédiatement pris des **mesures pour remédier à l'incident**. Nos équipes techniques ont [mesures techniques déjà prises : ex. "corrigé la faille de sécurité à l'origine de l'accès non autorisé"/"récupéré le support perdu"] et renforcent actuellement nos dispositifs de sécurité pour empêcher qu'un tel événement ne se reproduise. Par ailleurs, nous avons signalé cet incident à l'autorité de protection des données compétente (CNIL) conformément à nos obligations légales.

Comment vous protéger ? À titre préventif, nous vous recommandons de [**recommandations** : ex. "modifier le mot de passe de votre compte client sur notre site, par mesure de précaution, et éviter d'utiliser un mot de passe identique sur d'autres services"]. Surveillez également vos comptes en ligne et vos relevés (bancaires, etc.) dans les prochains mois. Si vous constatez des activités inhabituelles ou suspectes, n'hésitez pas à nous le faire savoir et à contacter les autorités compétentes si nécessaire.

Nous comprenons que cet incident puisse vous causer des **préoccupations**, et nous le regrettons sincèrement. La **sécurité de vos données personnelles** est une priorité absolue pour nous. Nous restons à votre entière disposition pour tout complément d'information ou assistance dont vous auriez besoin suite à cet événement. Vous pouvez nous joindre à tout moment à l'adresse [coordonnées du **DPO** ou service client dédié] pour poser vos questions ou exercer vos droits (accès, etc.).

Nous vous prions d'agréer, Madame, Monsieur, l'expression de nos salutations distinguées.

(Signature)

Shakira IPOULE

Déléguée à la Protection des Données (DPO)

Groupe B&B Hôtels

Annexe 3 : Correspondance avec le registre des traitements

Chaque incident recensé dans le présent registre se rattache à un ou plusieurs **traitements de données personnelles** figurant au registre des activités de traitement du groupe B&B Hôtels. Ci-dessous la correspondance pour la période considérée (2023–2025) :

- **Incident n°1 (10/02/2023)** – Concerne le traitement « *Gestion de la relation client (réclamations & fidélité)* » (fiche de registre **B&B/CRM/2025**). En effet, l’erreur d’envoi impliquait des données de clients extraites du système de gestion des réclamations/fidélité.
- **Incident n°2 (21/08/2023)** – Concerne le traitement « *Gestion des réservations clients* » (fiche **B&B/RES/2025**). La base de données compromise provenait du système de réservation hôtelière.
- **Incident n°3 (15/01/2024)** – Concerne le traitement « *Gestion du personnel et des candidatures (Ressources Humaines)* » (fiche **B&B/RH/2025**). Les données divulguées appartenaient au fichier RH (employés du groupe).
- **Incident n°4 (30/09/2024)** – Concerne le traitement « *Marketing digital et prospection (site web & newsletters)* » (fiche **B&B/MKT/2025**). L’intrusion a visé la base marketing (contacts de prospection / clients inscrits).
- **Incident n°5 (05/05/2025)** – Concerne le traitement « *Facturation et paiements clients* » (fiche **B&B/FIN/2025**). L’erreur d’envoi portait sur une facture issue du processus de facturation client.

Cette correspondance permet, pour chaque violation, de retrouver le **cadre du traitement** dans lequel elle s’est produite, et ainsi d’identifier plus aisément les responsables opérationnels, les mesures de sécurité associées, et les éventuelles **mentions légales** (information des personnes, durées de conservation, etc.) liées à ces traitements. En annexe de chaque fiche d’incident, un renvoi est fait vers la référence du traitement dans le registre afin de faciliter les vérifications croisées. Le registre des traitements et le registre des violations sont donc tenus de manière cohérente et complémentaire.

Annexe 4 : Modèle de plan d’amélioration post-incident

Après chaque incident, notamment les plus sérieux, le groupe B&B Hôtels élabore un **plan d’amélioration** visant à tirer les enseignements de la violation et à renforcer la protection des données. Ce plan, validé par le DPO et la Direction, comporte généralement les volets suivants :

- **Analyse de la cause racine** : Description détaillée des causes de l’incident (erreur humaine, défaut de procédure, faille technique, malveillance externe, etc.). Par exemple : « cause première identifiée : manque de vérification en double des destinataires email combiné à l’urgence ressentie – cause profonde : absence de procédure de contrôle ».

- **Mesures correctives immédiates** : Liste des actions entreprises dès la découverte de l'incident pour en limiter l'impact. Exemples : isolation d'un système compromis, rappel d'un email envoyé par erreur, changement de mots de passe, communication aux intéressés, etc. On indique pour chaque mesure la date de mise en œuvre et le responsable exécutant.
- **Actions préventives à moyen/long terme** : Ensemble des améliorations décidées pour éviter qu'un incident similaire ne se reproduise. Cela inclut des **mesures techniques** (ex. déploiement d'un nouvel outil de chiffrement, ajout d'un module de sécurité, mise à jour de logiciels) des **mesures organisationnelles** (ex. nouvelles procédures de validation, renforcement de la politique de gestion des accès) et des **mesures humaines** (ex. formation additionnelle, campagnes de sensibilisation ciblées). Chaque action est détaillée avec un échéancier et un responsable chargé de sa réalisation.
- **Suivi et évaluation** : Mécanismes prévus pour contrôler la bonne exécution du plan d'actions et pour évaluer leur efficacité. Par exemple : audits internes programmés, indicateurs de performance (KPI) comme le nombre d'incidents similaires sur une période donnée, retour d'expérience lors de réunions dédiées. On peut prévoir une **réunion de clôture** de l'incident lorsque toutes les mesures sont en place, afin de valider que le risque initial est réduit à un niveau acceptable.
- **Documentation et mise à jour** : Intégration des changements dans la documentation officielle de l'entreprise. Par exemple, mise à jour du **manuel de procédures de sécurité**, ajout de l'incident et des réponses apportées dans le registre des violations (ce document), éventuelle mise à jour du registre des traitements si de nouvelles mesures modifient les conditions de traitement, etc.
- **Communication et partage d'expérience** : Plan pour partager en interne (et si pertinent, en externe) les leçons apprises. Cela peut passer par un **rapport interne** présenté à la Direction Générale ou aux équipes, mettant en lumière ce qui a bien fonctionné et ce qui doit être amélioré dans la gestion de l'incident. En externe, cela peut inclure une communication aux partenaires ou sous-traitants si elle permet de renforcer collectivement la sécurité (sans exposer de failles exploitables).

Ce modèle de plan d'amélioration est adapté selon la gravité de l'incident : pour un incident mineur, certaines sections pourront être allégées, tandis que pour un incident majeur (ex. cyberattaque d'envergure), un plan détaillé et suivi sur plusieurs mois sera élaboré. L'objectif final est de **créer un cercle vertueux** : chaque violation doit permettre de renforcer la résilience de l'organisation, améliorer les pratiques et ainsi réduire la probabilité ou l'impact d'incidents futurs.

Conclusion

Le registre 2023–2025 démontre la capacité du groupe B&B Hôtels à détecter, analyser et traiter efficacement chaque violation de données personnelles. Les incidents recensés ont été gérés conformément au RGPD : notification à la CNIL sous 72 heures lorsque nécessaire, information des personnes en cas de risque élevé, et mise en œuvre de mesures correctives immédiates.

Deux tendances se dégagent :

- le **facteur humain** reste la première cause d'incident ;
- les **attaques externes** (phishing, intrusions) confirment la nécessité d'un haut niveau de sécurité technique.

Des actions concrètes ont déjà réduit ces risques : chiffrement des terminaux, renforcement des contrôles d'accès, formation continue du personnel et audits de sécurité.

L'objectif pour les années à venir est de **maintenir cette vigilance**, d'**améliorer la prévention** (formation, tests réguliers, suivi des sous-traitants) et d'**assurer une transparence totale** envers les autorités et les personnes concernées.

Ce registre constitue ainsi une **preuve de conformité et de maturité RGPD** du groupe B&B Hôtels.